



МЕХАНИЗМ БЛОКИРОВКИ УЧЕТНЫХ ЗАПИСЕЙ

Защита от брутфорс-атак и компромисс между
безопасностью и доступностью



Какую проблему мы решаем?

Атака грубой силы (Brute-force) — автоматизированный подбор учетных данных (логин/пароль).

Актуальность: Простые пароли, утечки данных, использование ботов.

Цель атаки: Получение несанкционированного доступа к учетной записи пользователя или администратора.

Вопрос: Как эффективно и с минимальными неудобствами для легитимных пользователей противостоять таким атакам?

Что такое механизм блокировки?

Это автоматический механизм безопасности, который временно или постоянно деактивирует учетную запись после превышения определенного порога неудачных попыток входа.

Ключевые параметры:

- **Порог блокировки (Threshold):** Число разрешенных неудачных попыток (например, 5).
- **Время блокировки (Lockout Duration):** На какой срок блокируется доступ (например, 15 минут, 1 час, до ручного сброса).
- **Сброс счетчика (Reset Counter):** Через какое время счетчик неудачных попыток обнуляется (например, через 30 минут без активности).

Какими способами можно блокировать?

1) Блокировка по имени пользователя (User ID Lockout):

Блокируется конкретная учетная запись. Наиболее распространенный тип.

Риск: Атака на отказ в обслуживании (DoS) — злоумышленник может намеренно блокировать многих пользователей.

Какими способами можно блокировать?

2) **Блокировка по IP-адресу** (IP Address Lockout):

Блокируются все попытки входа с подозрительного IP.

Плюс: Защищает всех пользователей от атакующего IP.

Минус: Вред для пользователей из-под общего IP (корпоративные сети, публичные Wi-Fi).

Какими способами можно блокировать?

3) Гибридная блокировка (Условная):

Пример: сначала применяется мягкая блокировка по IP (капча), затем — жесткая блокировка учетной записи.

Поведенческий анализ: Учет времени между попытками, геолокации, устройства.

Как могут обойти или использовать механизм против нас?

DoS против пользователей: Зная логины (из утечек), атакующий блокирует множество аккаунтов, вызывая волну обращений в поддержку.

Обход медленным брутфорсом (Low-and-Slow): Попытки делаются реже, чем время сброса счетчика (1 попытка в 31 минуту при сбросе через 30).

Атака на распределенные имена пользователей: Подбор не конкретного логина, а пароля для большого списка логинов (пароль "123456").

Утечка информации: Разные сообщения об ошибке для "неверный логин" и "аккаунт заблокирован" помогают атакующему составить список валидных пользователей.

Что можно использовать вместо или вместе с блокировкой?

- **CAPTCHA** после N-ой попытки: Останавливает ботов, но не мешает людям.
- **Увеличение задержки** (Login Delay/Throttling): После каждой неудачной попытки время ответа сервера увеличивается (2 сек, 4 сек, 8 сек...). Не блокирует, но делает брутфорс невыгодным.
- **Уведомления пользователя**: Email/SMS-оповещение о неудачных попытках входа и блокировке.
- **Белые списки IP-адресов**: Для критичных учетных записей (админы).
- **Двухфакторная аутентификация** (2FA): Кардинально снижает угрозу, даже если пароль подобран.

Рекомендации по реализации

- 1) Избегайте вечных блокировок. Используйте временные (15-60 минут).
- 2) Не сообщайте точную причину ошибки. Используйте единый, универсальный ответ: "Неверное имя пользователя или пароль" (без указания, что именно неверно и заблокирован ли аккаунт).
- 3) Внедряйте логирование и мониторинг. Записывайте IP, User-Agent, время для анализа инцидентов.

Рекомендации по реализации

4) Продумайте безопасный механизм разблокировки:

- По истечении времени автоматически.
- Через восстановление пароля по email (подтвержденному).
- Через обращение в поддержку (с проверкой личности).

5) Для административных аккаунтов используйте строгие правила и 2FA.

6) Рассмотрите гибридный подход: Капча -> Задержка -> Блокировка.

Пример работы механизма

Параметры системы: Порог = 5, Длительность блокировки = 30 мин, Сброс счетчика = 30 мин.

Сценарий:

- 1) Пользователь вводит неверный пароль 3 раза.
- 2) После 3-й попытки появляется CAPTCHA.
- 3) Атакующий бот не может решить капчу и делает еще 2 попытки.
- 4) После 5-й неудачи учетная запись блокируется на 30 минут.
- 6) На email пользователя приходит уведомление.
- 7) Через 30 минут счетчик сбрасывается, пользователь может попробовать войти снова (или воспользоваться "Забыли пароль").

Ключевые выводы

Механизм блокировки — необходимый, но не достаточный элемент защиты.

Это компромисс между безопасностью и доступностью.

Наивная реализация может привести к новым уязвимостям (DoS, утечка данных).

Рекомендуется комбинировать с другими мерами: капчей, задержками, 2FA, грамотным логированием.

Главный принцип: Усложнить и сделать невыгодной массовую автоматизированную атаку, минимально мешая законным пользователям.